

Принципы организации доступа к информационным ресурсам.

Махмудов Эльвин, Бобкова Вика

Принцип минимальных прав (Least Privilege)

- Предоставление пользователям, приложениям и устройствам строго необходимого для работы уровня прав.
- Цель — минимизация числа субъектов с доступом к критическим ресурсам для снижения рисков злоупотреблений.



Принцип разделения обязанностей (Separation of Duties)

- Распределение критически важных задач и полномочий между разными людьми или ролями.
- Цель — исключение ситуации, когда одно лицо может единолично контролировать и выполнять ключевой процесс, предотвращая мошенничество и ошибки.



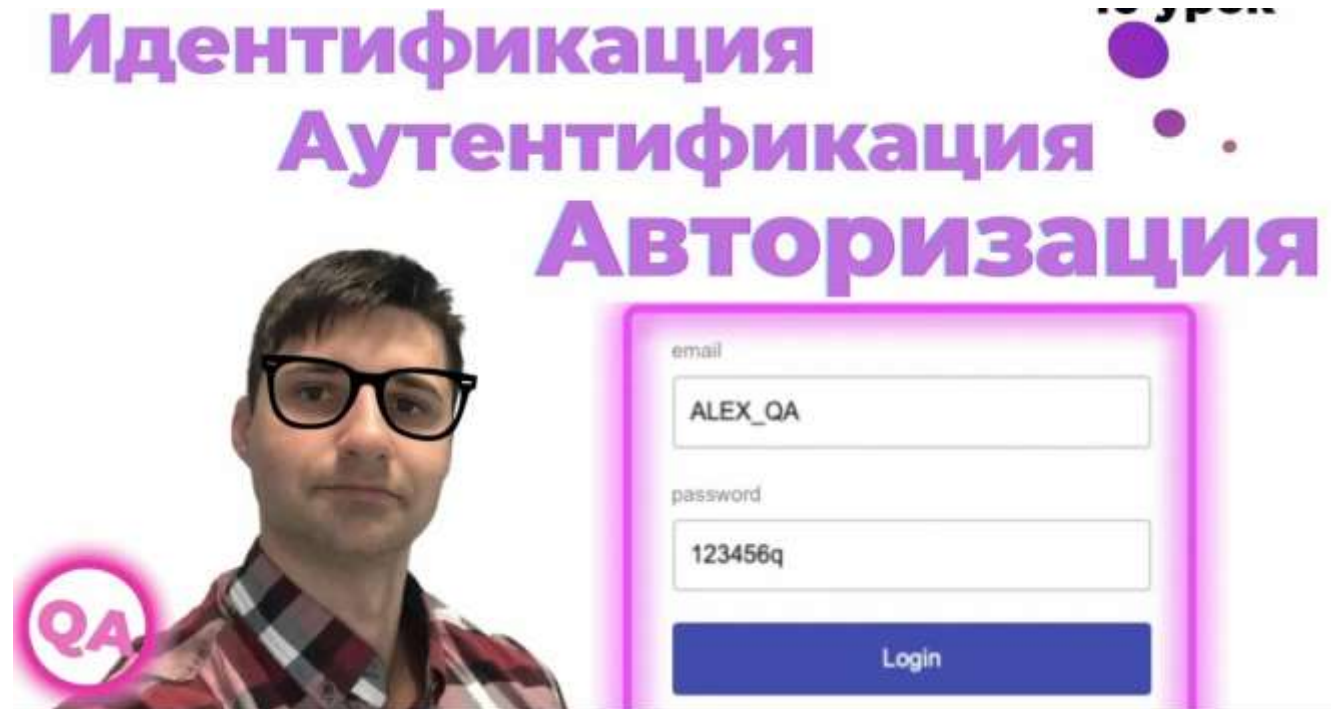
Принцип проверки и учета доступа (Audit and Accountability)

- Обязательная фиксация всех действий, связанных с доступом к ресурсам, в журналах аудита.
- Обеспечение возможности отслеживания и расследования инцидентов, установление ответственности за действия в системе.



Принцип управления идентификацией и аутентификацией

- Обязательная уникальная идентификация каждого пользователя в системе.
- Подтверждение подлинности личности с использованием надежных методов аутентификации (пароль, биометрия, многофакторная аутентификация).



Принцип разделения доступа (Access Control)

- Организация доступа на основе формальных правил и моделей (ролевой, атрибутивный, ACL) .
- Четкое определение, кто и какие операции может выполнять с данными в зависимости от роли, атрибутов или явных разрешений.



Принцип временных ограничений доступа (Time-Based Access)

- Ограничение доступа к ресурсам определенными временными интервалами (часы работы, период действия проекта) .
- Снижение рисков за счет автоматического блокирования доступа в нерабочее время или по завершении срока необходимости.

